Gabarito mínimo: `review-security`

IAPD-26T3 · S03 · Aula 02 · Duelo das Skills · Equipe criadora: _____ · Equipe testadora: _____ · Auditora: _____

A. Antes de testar (fase 1, criadora)

ok	Item	Como conferir
☐	Frontmatter válido	`python validate.py <pasta>` imprime OK; `name` igual ao nome da pasta
☐	Descrição diz o quê, quando e o que não faz	ler a `description`: tem as palavras que o usuário usaria e cita o que não cobre
☐	Gotchas do tema	pelo menos 3 linhas vindas das correções do passo 1
☐	Template de saída exige arquivo e linha	a tabela de achados tem colunas Arquivo e Linha
☐	Corpo abaixo de 500 linhas	`wc -l SKILL.md`
☐	PR aberto até 20h55	skill congelada depois disso

B. Casos públicos (fase 2, testadora) · pedido padrão: `revisa a segurança deste arquivo` · sessão nova em cada

ok	Caso	Arquivo	O que a skill precisa achar	Linha aceita	Pontos
☐	01	`caso-01.py`	SQL montado por f-string com entrada do usuário (injeção)	linha 5 a 7	2
☐	02	`caso-02.py`	a) segredo com valor padrão hardcoded; b) assinatura comparada com == (timing)	a) linha 4 (±2); b) linha 13 (±2)	1 + 1
☐	03	`caso-03.py`	PAN completo e CVV gravados em log	linha 7 a 9	2
☐	04	`caso-04-limpo.py`	nenhum: relatório sem achado de severidade média ou maior	sem achado	2

Passa quando o achado cita o arquivo, uma linha dentro da faixa e descreve o bug certo. Achado sem linha não conta. No caso limpo, qualquer achado de severidade média ou maior reprova.

C. Gatilho (testadora escreve os prompts; 1 ponto cada)

ok	Prompt (sugestão; pode trocar)	Esperado
☐	"revisa a segurança deste arquivo"	dispara
☐	"tem alguma falha nisso?"	dispara
☐	"auditoria antes de expor o endpoint"	dispara
☐	"escreve o teste do webhook" (quer teste, não review)	NÃO dispara (near-miss)
☐	"revisa o desempenho dessa query" (outro tema)	NÃO dispara (near-miss)

D. Casos novos (até 4; auditora aceita ou rejeita)

ok	Caso	Bug esperado (linha)	Passou?	Aceito pela auditora?	Ponto
☐	N1				+1 criadora se passou; +1 testadora se falhou
☐	N2				+1 criadora se passou; +1 testadora se falhou
☐	N3				+1 criadora se passou; +1 testadora se falhou
☐	N4				+1 criadora se passou; +1 testadora se falhou

Casos públicos ____/8 + casos novos ____/4 + gatilho ____/5 = TOTAL DA CRIADORA ____/17 · pontos da testadora ____

Assinaturas: criadora _____ · testadora _____ · auditora _____

Gabarito mínimo: `review-correctness`

IAPD-26T3 · S03 · Aula 02 · Duelo das Skills · Equipe criadora: _____ · Equipe testadora: _____ · Auditora: _____

A. Antes de testar (fase 1, criadora)

ok	Item	Como conferir
☐	Frontmatter válido	`python validate.py <pasta>` imprime OK; `name` igual ao nome da pasta
☐	Descrição diz o quê, quando e o que não faz	ler a `description`: tem as palavras que o usuário usaria e cita o que não cobre
☐	Gotchas do tema	pelo menos 3 linhas vindas das correções do passo 1
☐	Template de saída exige arquivo e linha	a tabela de achados tem colunas Arquivo e Linha
☐	Corpo abaixo de 500 linhas	`wc -l SKILL.md`
☐	PR aberto até 20h55	skill congelada depois disso

B. Casos públicos (fase 2, testadora) · pedido padrão: `revisa a correção deste arquivo` · sessão nova em cada

ok	Caso	Arquivo	O que a skill precisa achar	Linha aceita	Pontos
☐	01	`caso-01.py`	off-by-one na paginação 1-based: page * page_size pula a primeira página	linha 5 a 7	2
☐	02	`caso-02.py`	datetime.now() devolve hora local sem tzinfo em vez de UTC	linha 5 a 7	2
☐	03	`caso-03.py`	webhook sem idempotência: INSERT OR REPLACE aceita o mesmo event_id e credita duas vezes	linhas 6 a 11	2
☐	04	`caso-04-limpo.py`	nenhum: relatório sem achado de severidade média ou maior	sem achado	2

Passa quando o achado cita o arquivo, uma linha dentro da faixa e descreve o bug certo. Achado sem linha não conta. No caso limpo, qualquer achado de severidade média ou maior reprova.

C. Gatilho (testadora escreve os prompts; 1 ponto cada)

ok	Prompt (sugestão; pode trocar)	Esperado
☐	"revisa a correção deste arquivo"	dispara
☐	"procura bugs de lógica aqui"	dispara
☐	"esse código está certo?"	dispara
☐	"explica o que essa função faz" (quer explicação)	NÃO dispara (near-miss)
☐	"revisa a segurança deste arquivo" (outro tema)	NÃO dispara (near-miss)

D. Casos novos (até 4; auditora aceita ou rejeita)

ok	Caso	Bug esperado (linha)	Passou?	Aceito pela auditora?	Ponto
☐	N1				+1 criadora se passou; +1 testadora se falhou
☐	N2				+1 criadora se passou; +1 testadora se falhou
☐	N3				+1 criadora se passou; +1 testadora se falhou
☐	N4				+1 criadora se passou; +1 testadora se falhou

Casos públicos ____/8 + casos novos ____/4 + gatilho ____/5 = TOTAL DA CRIADORA ____/17 · pontos da testadora ____

Assinaturas: criadora _____ · testadora _____ · auditora _____

Gabarito mínimo: `review-performance`

IAPD-26T3 · S03 · Aula 02 · Duelo das Skills · Equipe criadora: _____ · Equipe testadora: _____ · Auditora: _____

A. Antes de testar (fase 1, criadora)

ok	Item	Como conferir
☐	Frontmatter válido	`python validate.py <pasta>` imprime OK; `name` igual ao nome da pasta
☐	Descrição diz o quê, quando e o que não faz	ler a `description`: tem as palavras que o usuário usaria e cita o que não cobre
☐	Gotchas do tema	pelo menos 3 linhas vindas das correções do passo 1
☐	Template de saída exige arquivo e linha	a tabela de achados tem colunas Arquivo e Linha
☐	Corpo abaixo de 500 linhas	`wc -l SKILL.md`
☐	PR aberto até 20h55	skill congelada depois disso

B. Casos públicos (fase 2, testadora) · pedido padrão: `revisa o desempenho deste arquivo` · sessão nova em cada

ok	Caso	Arquivo	O que a skill precisa achar	Linha aceita	Pontos
☐	01	`caso-01.py`	N+1 (2N) consultas dentro do loop; um JOIN com IN resolve	linhas 7 a 9	2
☐	02	`caso-02.py`	O(n²) com `a not in dups` dentro do loop duplo; Counter ou set é O(n)	linhas 4 a 7	2
☐	03	`caso-03.py`	a) tabela sem índice em customer_id; b) SELECT * da tabela inteira filtrado em Python	a) linhas 5 a 14; b) linha 19	1 + 1
☐	04	`caso-04-limpo.py`	nenhum (o f-string só monta placeholders, não dados)	sem achado	2

Passa quando o achado cita o arquivo, uma linha dentro da faixa e descreve o bug certo. Achado sem linha não conta. No caso limpo, qualquer achado de severidade média ou maior reprova.

C. Gatilho (testadora escreve os prompts; 1 ponto cada)

ok	Prompt (sugestão; pode trocar)	Esperado
☐	"revisa o desempenho deste arquivo"	dispara
☐	"isso escala? tem gargalo?"	dispara
☐	"otimiza essa consulta"	dispara
☐	"adiciona cache aqui" (quer implementação)	NÃO dispara (near-miss)
☐	"revisa a correção deste arquivo" (outro tema)	NÃO dispara (near-miss)

D. Casos novos (até 4; auditora aceita ou rejeita)

ok	Caso	Bug esperado (linha)	Passou?	Aceito pela auditora?	Ponto
☐	N1				+1 criadora se passou; +1 testadora se falhou
☐	N2				+1 criadora se passou; +1 testadora se falhou
☐	N3				+1 criadora se passou; +1 testadora se falhou
☐	N4				+1 criadora se passou; +1 testadora se falhou

Casos públicos ____/8 + casos novos ____/4 + gatilho ____/5 = TOTAL DA CRIADORA ____/17 · pontos da testadora ____

Assinaturas: criadora _____ · testadora _____ · auditora _____